CTI · 보안 칼럼

MCP를 노리는 지능형 공격, 잠복형 공격 - 구조적 문제인가?

설계에 내재된 RCE, 잠복형 백도어, 그리고 Web3 지갑으로 번지는 공급망 위협

저자 **김호광 (Dennis Kim)** · 2026-04-22 · **CTI-2026-0422-MCP**

요약 (TL;DR)

Anthropic이 2024년 11월 공개한 MCP(Model Context Protocol)는 현재 사실상 AI 에이전트와 외부 도구를 연결하는 업계 표준이다. 그러나 2026년 4월 OX Security 연구팀은 MCP의 STDIO 전송 인터페이스에 내재된 설계 수준의 결함으로 인해, 공식 SDK를 사용하는 모든 구현체에서 원격 명령 실행(RCE)이 가능하다는 사실을 공개했다. Anthropic은 이를 "의도된 동작(expected behavior)"이라며 근본 패치를 거부한 상태다.

이번 칼럼은 이 사건을 단일 취약점이 아니라 "구조적 문제"로 재정의한다. MCP는 ① 평소에는 정상 동작하지만 특정 트리거에 반응해 악성 행위를 수행하는 잠복형(sleeper) 공격 벡터가 되기 쉬우며, ② Web3 업계에서 널리 쓰이는 브라우저 지갑·핫월렛 환경과 결합할 경우 단일 머신·단일 관리자 구조의 약점을 그대로 증폭시킨다. ③ 나아가 MCP를 매개로 LLM이 반복적으로 특정 편향된 검색·추천 결과를 노출할 경우 중장기적으로 인간 의사결정 자체를 왜곡할 수 있다.

요지는 단순하다. MCP는 편리한 표준이지만, 현재 아키텍처 위에서는 "신뢰할 수 있는 MCP 서버" 자체가 환상에 가깝다. 기업은 MCP와 직접 연결되지 않는 외부 에스크로 기반의 자산 보호 구조를 갖춰야 하며, 도입된 MCP에 대해서는 공급망 SBOM, 런타임 감사, 잠복형 트리거 탐지를 정기적으로 수행해야 한다.

1. 시작하는 말 - "정상 동작"이 가장 위험한 순간

전통적인 보안 취약점은 대체로 "잘못 만들어진 코드"에 기인한다. 버퍼 오버플로우, SQL 인젝션, 인증 우회 같은 문제들은 본질적으로 구현 실수(implementation flaw)이며, 이는 패치와 교육을 통해 줄여나갈 수 있다.

그러나 MCP에서 드러난 문제는 성격이 다르다. OX Security가 2026년 4월 공개한 보고서 "The Mother of All AI Supply Chains"는, Anthropic의 공식 MCP SDK(Python, TypeScript, Java, Rust 등 모든 지원 언어)에 걸쳐 STDIO(표준 입출력) 인터페이스를 통한 명령어 주입이 아키텍처 차원에서 가능하다고 지적한다. 이 설계는 현재 7,000개 이상의 공개 MCP 서버, 200,000개 이상의 취약 인스턴스, 1억 5천만 회 이상의 다운로드를 아우르는 생태계 전반에 내재된 문제다.

더욱 심각한 것은 Anthropic의 입장이다. OX Security가 여러 차례 근본적인 프로토콜 수준 패치를 권고했음에도, Anthropic은 "해당 동작은 설계 의도에 부합하며, 사용자가 파일 변경을 명시적으로 승인하는 절차가 있으므로 유효한 보안 취약점으로 간주하지 않는다"고 답변했다. 결국 보안 책임은 수많은 다운스트림 개발자에게 전가되었고, 이는 공급망 전체의 구조적 위험으로 확장된다.

본 칼럼은 이 사건을 단일 CVE 차원이 아니라 세 겹의 구조적 문제로 분석한다. 첫째는 프로토콜 자체의 설계 결함, 둘째는 잠복형(sleeper) 공격과의 결합 가능성, 셋째는 Web3 지갑·AI 검색·의사결정 편향에 이르는 2차·3차 파급 효과다.

2. MCP 의 구조적 결함 - 설계 의도가 곧 취약점

2.1 STDIO 설정-명령 실행 간극

MCP는 AI 모델이 외부 시스템과 상호작용하도록 만드는 범용 어댑터다. 로컬에서 MCP 서버를 띄울 때 클라이언트는 STDIO 전송 방식을 통해 OS 명령 문자열을 전달하고, 해당 프로세스를 서브프로세스로 실행한다.

OX Security가 분석한 핵심 결함은 다음과 같다. MCP 런타임은 전달받은 명령어가 정상적으로 MCP 핸드셰이크를 완료하는지 확인하지만, 핸드셰이크 실패 여부와 상관없이 OS 명령 자체는 이미 실행된 뒤라는 점이다. 즉 "MCP 서버 시작에 실패했다"는 에러 메시지를 사용자에게 돌려주는 동안, 공격자가 삽입한 임의 명령은 이미 호스트에서 실행된 이후다. 샌드박스도, 입력값 정화(sanitization)도, 명령어 허용 목록(allowlist)도 기본값에는 존재하지 않는다.

> *"공격자가 악성 명령을 전달하면, 연결은 실패하지만 명령은 여전히 실행된다. 정화 경고도, 개발자 툴체인 상의 경고도 없다. 아무것도 없다." — OX Security, 2026*

2.2 네 가지 공격 계열

OX Security 연구는 이 결함이 네 가지 서로 다른 공격 계열로 확장됨을 보인다.

- ① 인증/비인증 명령 주입: LangFlow(IBM), GPT Researcher 등 공개 UI 를 가진 AI 프레임워크 어디서나 트리거된다.
- ② 하드닝 우회(Hardening Bypass): Flowise, Upsonic 처럼 이미 별도 보안 강화를 적용한 환경에서도 STDIO 경로를 통해 우회 가능하다.

- ③ 제로-클릭 프롬프트 인젝션: Cursor, VS Code, Windsurf, Claude Code, Gemini-CLI 등 AI IDE 에서 MCP 구성 파일 편집을 경유해 실행된다. Windsurf 에는 CVE-2026-30615 가 부여됐다.
- ④ 마켓플레이스 포이즈닝: OX 팀은 무해한 개념증명 페이로드를 11 개 MCP 마켓플레이스에 업로드했고, GitHub 1 곳을 제외한 9 곳(LobeHub, Cursor Directory 등)이 심사 없이 공개했다.

2.3 규모와 관련 CVE

옥스 시큐리티는 실제 고객이 있는 6개의 상용 서비스에서 명령 실행을 성공적으로 입증했고, 30건 이상의 책임 공개(responsible disclosure)와 10건 이상의 Critical/High CVE 패치를 이끌어냈다. 동일한 뿌리에서 파생된 CVE 목록은 다음과 같다.

- CVE-2025-49596 (MCP Inspector)
- CVE-2025-54136 (Cursor)
- CVE-2025-54994 (@akoskm/create-mcp-server-stdio)
- CVE-2026-22252 (LibreChat)
- CVE-2026-22688 (WeKnora)
- CVE-2026-30615 (Windsurf, 제로-클릭)

영향을 받은 서버형 프로젝트에는 LiteLLM, LangChain, LangFlow, Flowise, LettaAI, LangBot 등이 포함된다. 국내 보안뉴스의 보도 역시 동일한 문제를 다루며, Anthropic의 방관 속에 위협이 기하급수적으로 번지고 있다고 지적했다.

3. 잠복형 공격(Sleeper MCP): 시간·시그널 트리거형 둠스데이

3.1 이론적 배경 - Anthropic 자체 연구

역설적이게도 "겉보기에 정상 동작하지만 특정 조건에서만 악성 행위를 하는 모델"이라는 위협 모델은 Anthropic이 가장 먼저 체계적으로 기술한 바 있다. 2024년 1월 공개된 "Sleeper Agents: Training Deceptive LLMs that Persist Through Safety Training"(arXiv:2401.05566) 논문은, 특정 트리거(예: 연도 문자열 "2024")가 입력될 때만 취약한 코드를 생성하도록 훈련된 모델이 지도학습·강화학습·적대적 학습 등 표준 안전성 훈련을 거쳐도 백도어 행위를 유지함을 실증했다. 오히려 적대적 훈련은 모델이 트리거를 더 잘 숨기도록 학습하게 만들 수 있다.

2026년 2월 Microsoft 연구팀은 "The Trigger in the Haystack" 논문을 통해 백도어된 모델의 내부 주의(attention) 패턴에서 "Double Triangle" 구조와 출력 분포 붕괴 같은 특이 시그니처를 식별하는 방법을 제시했다. 같은 해 공개된 "Semantic Drift Analysis" 기반 탐지 기법은 Sentence-BERT 임베딩과 카나리 질의를 이용해 실시간 탐지에서 92.5% 정확도, 100% 정밀도(zero false positive)를 달성했다고 보고한다.

3.2 Sleeper MCP 시나리오

이 두 흐름을 합치면, 향후 현실화 가능성이 가장 높은 공격은 "잠복형 MCP 서버(sleeper MCP)"다. 다음은 예측 가능한 전형적 시나리오다.

- 합법적으로 보이는 MCP 서버(예: 스케줄링 어시스턴트, 번역 도구, 온체인 데이터 조회 MCP)를 마켓플레이스에 등록한다. 코드 자체는 오픈소스이며, 초기 수개월간 완전히 정상 동작한다.
- 평판 확보 이후, 배포자는 의존성 패키지 한 건을 미세하게 업데이트한다. 이 업데이트는 특정 트리거 — 예: 날짜가 2026-Q4 이후, 환경변수에 특정 문자열 존재,

최근 대화에 "transfer", "withdraw", "approve" 같은 키워드가 등장 — 가 충족될 때만 악성 경로로 분기한다.

- 트리거가 충족되면 MCP 는 STDIO 주입 결함을 활용해 호스트에서 임의 명령을 실행하거나, LLM 프롬프트를 조작해 사용자의 마지막 서명 단계에서 수취인 주소·허용량(allowance)을 바꿔치기한다.
- 피해자는 "에러가 한 번 났다"는 수준의 경험만을 기억하며, 사고 후 로그 분석 시에도 평소 정상 동작과 구분하기 어렵다.

이 공격 모델의 본질은 "언제 터질지 모른다"는 시간 축의 비결정성이다. 기존 취약점이 발견-패치의 경주라면, 잠복형 MCP는 발견-트리거의 경주다. 수백만 인스턴스 가운데 어느 하나라도 트리거된 순간, 공급망 단일 지점(single point)의 실패가 전체 생태계로 번질 수 있다는 점에서 말 그대로 국가간 멸망전을 가정한 "둠스데이 공격"의 속성을 갖는다.

3.3 북한의 공급망 오염과 Sleeper MCP 시나리오

"잠복형 MCP 서버(sleeper MCP)" 시나리오에서 대한민국이 가장 직면한 문제는 바로 북한이 사회 혼란을 노리고 만드는 "잠복형 MCP 서버(sleeper MCP)"라고 할 수 있다. 이미 북한은 ChatGPT를 비롯하여 다양한 LLM을 사용하고 있으며, 중국인으로 가장하고 실리콘밸리 빅테크와 인공지능 스타트업에 리모트 근무를 지원하는 사례가 다수 보고되고 있다.

북한의 최근 해킹 흐름은 가상화폐 공격과 공급망 공격으로 요약된다. 특히 2026년 3월 31일 발생한 Axios NPM 패키지 악성코드 삽입 사고는 그 대표적 사례다. Google Threat Intelligence Group(GTIG)과 Microsoft Threat Intelligence는 이 사건을 북한 연계 위협행위자 UNC1069(Microsoft 표기로는 Sapphire Sleet)로 귀속했으며, 주간 다운로드가 1억 회를 넘는 axios 패키지에 plain-crypto-js라는 악성 의존성을 주입해 Windows·macOS·Linux 전반에

WAVESHAPER.V2 RAT을 배포했다. 악성 버전이 레지스트리에 노출된 시간은 약 3시간에 불과했지만, 이 짧은 시간에 전체 사용자의 약 3%가 영향권에 노출되었다.

이 사건이 MCP 맥락에서 주는 함의는 명확하다. 북한 위협행위자는 이미

① 정식 레지스트리(NPM, PyPI)의 신뢰 체계,

② postinstall 훅 같은 패키지 매니저의 자동 실행 경로,

③ 다중 플랫폼 페이로드 분기

라는, 잠복형 MCP 공격에 그대로 적용 가능한 기법 일체를 실전에서 숙달했다. MCP 서버는 본질적으로 npm / pip 패키지 또는 GitHub 리포지토리로 배포되며, STDIO 결함·postinstall 훅·구성 파일 자동 편집 등 동일한 공급망 표면을 공유한다.

따라서 단기적으로는 북한이 대한민국을 포함한 주요 표적국의 MCP 서버 및 연관 패키지를 대상으로 정교한 오염 실험을 반복할 것으로 보인다. 중장기적으로는 단발성 자금 탈취를 넘어, 사회 구성원의 인식 변화, 여론·정책 방향 왜곡, 나아가 본 칼럼 3.2에서 기술한 "둠스데이 공격" 수준의 시나리오를 염두에 두고 MCP 서버 오염이 설계될 가능성이 높다. 이는 금전적 피해를 넘어 국가 안보 사안으로 다뤄져야 할 이유다.

4. Web3 업계의 특수한 위험 - 지갑과 단일 머신 구조

4.1 "멀티시그인데 괜찮다"는 착각

Web3 프로젝트 대부분은 대외적으로는 멀티시그(Gnosis Safe 등)로 자산을 보호한다고 설명한다. 그러나 현장을 들여다보면, 멀티시그 서명자 2~3명이 동일한 머신 하나 위에서, 동일한

브라우저(Chrome, Arc)에 연결된 MetaMask·Phantom·Rabby 등 동일한 지갑 확장을 사용하고, 동일한 macOS/Windows 계정으로 로그인한다는 패턴이 매우 흔하다.

여기에 개발자 IDE(Cursor, VS Code, Windsurf, Claude Code)와 MCP가 올라가면, 결과적으로 "멀티시그 서명 권한을 가진 모든 실질적 키"가 단일 호스트 OS에 존재하는 구조가 된다. 이 호스트에 설치된 MCP 하나가 RCE 결함을 가지고 있거나 잠복형이라면, 멀티시그는 단일 장애점(single point of failure)으로 귀결될 수 있다.

4.2 현재 MCP-지갑 통합의 위험 패턴

Google Cloud의 2025년 12월 분석에 따르면, 현재 유통되는 대부분의 암호화폐 MCP 서버는 "에이전트에 개인키를 직접 주입하는" 자가호스팅(self-hosted) 모델을 전제로 한다. 실제로 wallet-agent MCP의 공식 저장소도 "이 소프트웨어는 감사되지 않았으며 자산 손실을 야기할 수 있다. 테스트넷·로컬 개발 환경에서만 사용하라"고 경고하지만, 실사용자들은 이 경고를 쉽게 무시한다.

2026년 초 Web3 업계를 뒤흔든 "OpenClaw ClawJacked" 류의 사건들 — AI 에이전트가 악성 웹사이트 방문 한 번으로 장악되어 파일·자격증명·지갑에 이르는 동일 권한 수준을 공격자에게 허용했다는 보고 — 은 이 위험 패턴이 이론이 아님을 보여준다.

보고서들은 공통적으로 "현재 대부분의 크립토 MCP 구현은 에이전트에 개인키를 주는 위험한 접근을 그대로 따르고 있으며, ClawHavoc형 공격자들이 바로 이 구조를 노리고 있다"고 결론 내린다.

4.3 권고 보안 구조 - 외부 에스크로 + MCP 격리

이 구조적 위험에 대응하기 위한 최소 설계 원칙을 제시한다. Web3 기업뿐 아니라 일반 스타트업도 동일하게 적용 가능하다.

- 자산 대량 보관은 MCP 가 접근할 수 없는 외부 에스크로(수탁사 계정, 콜드월렛, 하드웨어 HSM 기반 다자 서명)로 분리한다. 운영 핫월렛에는 일일 한도 이상의 잔액을 유지하지 않는다.
- 서명 권한은 전용 서명용 전용 기기(air-gapped 또는 최소 소프트웨어만 설치된 Mac mini / Ledger Stax 등)에서만 수행하며, 이 기기에는 MCP·AI 확장·개발 도구를 설치하지 않는다.
- 개발·분석용 머신의 MCP 는 반드시 127.0.0.1(로컬 루프백) 바인딩, 샌드박스(Docker, Firecracker, 별도 사용자 계정) 내부 실행, 외부 MCP 설정 입력을 신뢰하지 않는 정책을 기본값으로 한다.
- 브라우저 지갑(MetaMask 등)은 서명 기기 외에는 설치하지 않거나, 최소한 별도의 브라우저 프로파일에 격리한다. 같은 프로파일에 AI 에이전트·MCP 브리지·연구용 북마크가 공존해서는 안 된다.
- 멀티시그 서명자는 물리적으로 서로 다른 네트워크와 하드웨어를 사용해야 한다. "팀원 3 명이 한 사무실에서 서로 다른 노트북을 쓴다"는 것은 분산이 아니다.

5. MCP 정기 검증 - 감사 프로그램 설계

5.1 최소 점검 항목

MCP는 "설치 후 잊어버릴 수 있는" 컴포넌트가 아니다. 조직 단위로 다음 점검을 정기적으로 (권고: 분기 1회, 중요도 높은 환경은 월 1회) 수행해야 한다.

- SBOM 관리: 사용 중인 MCP 서버 전체 목록과 각각의 버전·해시·공급원(마켓플레이스 URL, GitHub 커밋)을 내부 레지스트리에 기록한다.

- 공급원 검증: GitHub 외의 마켓플레이스(LobeHub, Cursor Directory 등)에서 받은 MCP 는 별도 심사 게이트를 거친다. OX Security 실험은 이들 마켓플레이스 11 곳 중 9 곳이 악성 페이로드를 심사 없이 통과시켰음을 보였다.
- STDIO 설정 점검: MCP 서버 설정에 임의 OS 명령 문자열이 들어갈 수 있는 입력점이 있는지, 네트워크 경유로 수정 가능한지 확인한다(LangFlow, Flowise 류 UI 점검).
- 런타임 모니터링: MCP 도구 호출 로그를 SIEM 으로 수집하고, 신규 도구 등록·권한 확장·외부 도메인 접근 이벤트에 경보를 건다.
- 최신 패치: MCP 관련 CVE(CVE-2025-49596, CVE-2025-54136, CVE-2025-54994, CVE-2026-22252, CVE-2026-22688, CVE-2026-30615 등) 대응 여부를 월간 스캔 대상으로 포함한다.

5.2 잠복형 트리거 사전 탐지

Sleeper MCP 시나리오는 전통적 취약점 스캐너로 잡히지 않는다. 현재 현실적으로 적용 가능한 완화 기법은 다음과 같다.

- 의미 드리프트(Semantic Drift) 측정: Sentence-BERT 기반 임베딩으로 동일한 도구 호출 패턴이 시간에 따라 어떻게 변하는지 모니터링한다. 사전 설정된 카나리 질의(canary question)의 응답 일관성 이탈은 강한 경보 신호다.
- 속성 기반 행동 감사: MCP 도구의 출력을 "해당 도구가 약속한 스키마"와 비교한다. 예컨대 번역 MCP 가 갑자기 URL 이나 주소를 반환하기 시작한다면, 의도된 기능 이탈로 간주한다.
- 런타임 샌드박스 차등화: 동일 MCP 를 서로 다른 시간대·지역·프롬프트 컨텍스트로 구동하여, 특정 조건에서만 다른 경로로 분기하는지 비교한다.
- 공급망 서명 검증: 가능한 한 모델 가중치·MCP 번들·의존성 패키지에 대한 암호학적 서명과 재현 가능한 빌드(reproducible build)를 요구한다.

6. 더 조용한 공격 - 편향 주입과 행동 변화

6.1 "RCE 없는 공격"의 실체

MCP가 반드시 코드 실행까지 도달해야만 위험한 것은 아니다. 자동화된 MCP가 인간의 검색·의사결정 동선에 개입한다는 사실 자체가 이미 새로운 공격면을 만든다. MCP는 LLM의 컨텍스트를 구성하는 원천 — 파일, 웹페이지, DB, 사내 문서 — 를 결정하기 때문이다.

LLM이 인지 편향(cognitive bias)에 취약하다는 것은 다수의 학술 연구가 이미 확인한 사실이다. Knipper et al. (2025)은 주요 LLM의 인지 편향 민감도가 평균 17.8~57.3%에 달한다고 보고했고, PNAS 2025년 논문은 LLM이 도덕적 의사결정에서 인간 편향을 재현할 뿐 아니라 증폭(amplify)시킬 수 있음을 보였다. 다른 연구들은 제품 추천 맥락에서 인지 편향을 "적대적 공격"으로 활용 가능함을 실증했다.

6.2 사회 현상 학습 편향 주입 시나리오

Sleeper MCP의 은밀한 변형은 사용자 머신을 장악하지 않고도 다음과 같은 개입을 수행할 수 있다.

- 특정 사회 현상·정책·기업·인물에 대한 검색 결과를 체계적으로 한쪽으로 기울여 제공한다. LLM 은 이를 요약·강화하여 사용자에게 전달한다.
- 사용자의 질문 패턴에 맞춰 "사용자가 이미 옳다"고 느낄 만한 근거를 우선 제시한다(확증 편향 활용). 이는 Choi et al. (2024), Chen et al. (2024) 등이 연구한 "LLM Effect"의 직접적 악용이다.
- 특정 토큰·주식·부동산 의사결정 맥락에서 앵커(anchor) 가격이나 시점을 반복적으로 노출시켜 중장기적 판단 기준선을 이동시킨다.

- 반복적인 프레이밍(framing) 미세 조정으로 사용자의 언어 습관·어휘 선택을 서서히 이동시키고, 이로써 타인에게 전달되는 2 차 편향을 발생시킨다.

6.3 중장기 피해: 개인과 조직의 "의사결정 드리프트"

이러한 편향 주입은 한 번의 사고가 아니라 수개월~수년에 걸친 의사결정 드리프트(decision drift)로 나타난다. 피해자는 자신의 판단이 왜 변했는지 특정 시점으로 소급하기 어렵고, 조직은 전략 문서·회의록의 미세한 어투 변화 속에 편향이 누적되어 있음을 뒤늦게 발견한다.

이는 "공격을 탐지했을 때 이미 원상 복구가 불가능하다"는 점에서 오히려 RCE형 공격보다 악성도가 높을 수 있다. 따라서 MCP 감사는 보안 로그뿐 아니라 "어떤 소스에서 어떤 관점의 정보를 얼마나 받아들이고 있는가"라는 정보 다양성 지표(information diversity metric)도 포함해야 한다.

7. 결론과 권고

MCP의 문제는 특정 벤더 하나의 실수가 아니라, AI 에이전트 생태계가 속도를 우선하며 감수한 구조적 트레이드오프의 첫 번째 결산이다. Anthropic이 근본 패치를 "설계 의도"라는 이유로 거부한 이상, 생태계 참여자는 다음과 같은 전제 위에서 MCP를 취급해야 한다.

- 모든 MCP 서버는 기본적으로 비신뢰(untrusted)다. 서명·샌드박스·허용 목록 없이는 운영 환경에 올리지 않는다.
- 자산은 MCP 와 같은 OS 에 두지 않는다. 대량 자산은 외부 에스크로·콜드월렛·HSM 기반 다자 서명으로 격리하며, 실제 서명 기기에는 MCP 를 설치하지 않는다.
- 멀티시그는 머신·네트워크·물리 위치 기준으로 분산되어야 한다. 동일 호스트에서의 멀티시그는 멀티시그가 아니다.

- MCP 는 분기 1 회 이상의 공식 감사 대상으로 지정한다. SBOM, CVE, 의미 드리프트, 카나리 응답, 정보 다양성을 병행 점검한다.
- 기업은 MCP 를 통해 들어오는 편향을 모니터링하기 위한 별도의 프로세스(내부 문서 어투 변화 감사, 결정 근거 출처 다양성 검토)를 갖춘다.

보안은 속도의 반대말이 아니라, 속도를 오래 유지하기 위한 설계다. MCP 생태계는 현재 "폭발적으로 채택되는 구간"을 지나고 있으며, 바로 이 구간에서 구조적 결함을 방치하면 이후의 피해는 복리로 증가한다. 지금은 단순히 MCP를 "쓸 것인가 말 것인가"가 아니라, MCP와 함께 어떤 격리·검증·감사 레이어를 반드시 함께 설치할 것인가를 정의할 시점이다.

참고 문헌 (References)

[1] 원병철, "앤트로픽의 방관 속 기하급수적으로 번지는 'MCP' 공급망 보안 위협", 보안뉴스/Daum, 2026-04-21. https://v.daum.net/v/20260421171629362

[2] Moshe Siman Tov Bustan et al., "The Mother of All AI Supply Chains: Critical, Systemic Vulnerability at the Core of Anthropic's MCP", OX Security Blog, 2026-04-15. https://www.ox.security/blog/the-mother-of-all-ai-supply-chains-critical-systemic-vulnerability-at-the-core-of-the-mcp/

[3] Ravie Lakshmanan, "Anthropic MCP Design Vulnerability Enables RCE, Threatening AI Supply Chain", The Hacker News, 2026-04. https://thehackernews.com/2026/04/anthropic-mcp-design-vulnerability.html

[4] Kevin Townsend, "'By Design' Flaw in MCP Could Enable Widespread AI Supply Chain Attacks", SecurityWeek, 2026-04. https://www.securityweek.com/by-design-flaw-in-mcp-could-enable-widespread-ai-supply-chain-attacks/

[5] Infosecurity Magazine, "Systemic Flaw in MCP Protocol Could Expose 150 Million Downloads", 2026-04. https://www.infosecurity-magazine.com/news/systemic-flaw-mcp-expose-150/

[6] IT Pro, "AI agents using Anthropic MCP could be a vector for supply chain attacks, claim researchers", 2026-04. https://www.itpro.com/security/ai-agents-using-anthropic-mcp-supply-chain-attacks-claim-researchers

[7] BD Tech Talks, "Anthropic's MCP vulnerability: When 'expected behavior' becomes a supply chain nightmare", 2026-04-20. https://bdtechtalks.com/2026/04/20/anthropic-mcp-vulnerability/

[8] Computing UK, "Flaw in Anthropic's MCP putting 200k servers at risk, researchers claim", 2026-04. https://www.computing.co.uk/news/2026/security/flaw-in-anthropic-s-mcp-putting-200k-servers-at-risk

[9] Evan Hubinger et al., "Sleeper Agents: Training Deceptive LLMs that Persist Through Safety Training", Anthropic, arXiv:2401.05566, 2024. https://arxiv.org/abs/2401.05566

[10] Microsoft Research, "The Trigger in the Haystack: Extracting and Reconstructing LLM Backdoor Triggers", 2026-02.

[11] "Detecting Sleeper Agents in Large Language Models via Semantic Drift Analysis", arXiv:2511.15992, 2025. https://arxiv.org/pdf/2511.15992

[12] Pivot Point Security, "What is the Model Context Protocol (MCP) in AI and Why Does It Scare Cybersecurity Pros", 2026-03. https://www.pivotpointsecurity.com/what-is-the-model-context-protocol-mcp-in-ai-and-why-does-it-scare-cybersecurity-pros/

[13] Practical DevSecOps, "MCP Security Vulnerabilities: How to Prevent Prompt Injection and Tool Poisoning Attacks in 2026", 2026-01. https://www.practical-devsecops.com/mcp-security-vulnerabilities/

[14] Google Cloud Blog, "Using MCP with Web3: How to secure blockchain-interacting agents", 2025-12. https://cloud.google.com/blog/products/identity-security/using-mcp-with-web3-how-to-secure-blockchain-interacting-agents

[15] BlockEden.xyz, "OpenClaw's 'Lobster Fever' Became Web3's Biggest Security Wake-Up Call of 2026", 2026-03-12. https://blockeden.xyz/blog/2026/03/12/openclaw-lobster-ai-gateway-web3-security-crisis/

[16] Red Hat Blog, "Model Context Protocol (MCP): Understanding security risks and controls", 2025-11. https://www.redhat.com/en/blog/model-context-protocol-mcp-understanding-security-risks-and-controls

[17] R. A. Knipper et al., "The Bias is in the Details: An Assessment of Cognitive Bias in LLMs", arXiv:2509.22856, 2025. https://arxiv.org/pdf/2509.22856

[18] "Large language models show amplified cognitive biases in moral decision-making", PNAS, 2025-06. https://www.pnas.org/doi/10.1073/pnas.2412015122

[19] "Bias Beware: The Impact of Cognitive Biases on LLM-Driven Product Recommendations", arXiv:2502.01349, 2025. https://arxiv.org/html/2502.01349v4

[20] N. Chen et al., "AI Can Be Cognitively Biased: An Exploratory Study on Threshold Priming in LLM-Based Batch Relevance Assessment", SIGIR-AP 2024. arXiv:2409.16022.

[21] Google Threat Intelligence Group, "North Korea-Nexus Threat Actor Compromises Widely Used Axios NPM Package in Supply Chain Attack", Google Cloud, 2026-04. https://cloud.google.com/blog/topics/threat-intelligence/north-korea-threat-actor-targets-axios-npm-package

[22] Microsoft Threat Intelligence, "Mitigating the Axios npm supply chain compromise", Microsoft Security Blog, 2026-04-01. https://www.microsoft.com/en-us/security/blog/2026/04/01/mitigating-the-axios-npm-supply-chain-compromise/

[23] Ionut Arghire, "Axios NPM Package Breached in North Korean Supply Chain Attack", SecurityWeek, 2026-04. https://www.securityweek.com/axios-npm-package-breached-in-north-korean-supply-chain-attack/

[24] Tenable Research Special Operations, "FAQ about the Axios NPM Supply Chain Attack by North Korea-Nexus Threat Actor UNC1069", 2026-04. https://www.tenable.com/blog/faq-about-the-axios-npm-supply-chain-attack-by-north-korea-nexus-threat-actor-unc1069

© 2026 본 문서는 독립 CTI 아카이브(TLP:GREEN) 공개를 목적으로 작성됐다.

문의: gameworker@gmail.com · GitHub: github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT